

Gesundheitsforschung GmbH EU SCC 审查报告

EU SCC Compliance Review Report — Gesundheitsforschung GmbH

Date: 20260808 | Rating: HIGH

文件概要

第一章 文件概要

1.1 SCC文档基本信息

- 模块类型: 文件声明为模块二 (Module Two: Controller to Processor)。经审查, 此模块选择与预期一致, 正确无误。
- 签署日期: 未提供。
- 适用法律: 未提供。

1.2 数据输出方与输入方身份及角色

- 数据输出方: 根据模块二的定义, 数据输出方为控制者 (Controller)。具体身份未提供。
- 数据输入方: 根据模块二的定义, 数据输入方为处理器 (Processor)。具体身份未提供。
- 缔约方完整性: 审查发现, 附录I.A部分识别的缔约方少于2个。对接条款 (Clause 7) 下的相关方可能亦未列明。

1.3 传输数据概述

- 涉及的数据类别: 传输描述中包含健康/医疗相关数据术语, 但文件未声明涉及GDPR第9条所规定的特殊类别数据。
- 涉及的数据主体类别: 未提供。
- 传输目的概述: 未提供。

1.4 文档结构完整性检查

经审查, 标准合同条款 (Clauses 1-18) 及附录 (Annexes I-IV) 的框架结构齐全。然而, 关键附录内容存在重大缺失或问题:

- 1 附录I (Annex I): 已提供但内容不完整 (见上述1.2及1.3点)。
- 2 附录II (Annex II): 技术与组织措施 (Technical and Organisational Measures) 内容为空或无法解析。根据GDPR第28(1)条及SCCs要求, 缺乏具体措施描述意味着无法证明提供了充分的数据保护保障。
- 3 附录III (Annex III): 未提供。
- 4 附录IV (Annex IV): 未提供。

1.5 核心合规问题摘要

基于初步审查, 本SCC文件存在以下关键缺陷, 导致整体风险评估为高风险 (HIGH):

- 1 标准条款被修改: 发现1处对标准条款的修改, 即第15(a)条将数据输入方收到具有法律约束力的披露请求后“立即 (promptly)”通知的义务, 修改为“法律许可时”通知, 这削弱了法定义务 [1]。
- 2 向非充分性认定第三国传输: 数据传输目的地为印度 (India)。印度未获得欧盟委员会的充分性认定。
- 3 缺乏传输影响评估 (TIA): 未提供针对印度数据传输的TIA文件。根据GDPR第44条及Schrems II案 (C-311/18) 判决, 在使用第46条传输工具 (如SCCs) 前, 必须进行并记录TIA [2][3]。
- 4 缺乏补充措施: 针对向印度的传输, 未发现任何有效的技术、合同或组织性补充措施, 以确保达到欧盟基本等同的保护水平。这与EDPB Recommendations 01/2020的要求不符。

5 特殊类别数据处理风险: 传输描述暗示可能涉及健康数据, 但未按GDPR第9条要求声明合法处理基础, 仅凭SCCs可能不足以进行此类传输。

References: Commission Implementing Decision (EU) 2021/914 Recital (22) / Clause 15; Commission Implementing Decision (EU) 2021/914 Recital (21) / Clause 14; EDPB Recommendations 01/2020 Step 3

总体合规评级

第二章 总体合规评级

(1) 总体评级及其理由

总体评级：高风险

理由：

本次审查发现, 数据传输安排存在多项严重缺陷, 导致无法依据标准合同条款 (SCC) 确保对个人数据的充分保护。主要高风险问题包括：1) 向不具备充分性决定的第三国 (印度) 进行传输, 但未提供必要的传输影响评估 (TIA), 也未实施任何经确认的补充措施, 这直接违反了Schrems II案 (C-311/18) 确立的原则及EDPB Recommendations 01/2020的要求 [3]；2) 标准合同条款本身的关键义务被不当修改, 削弱了数据接收方的通知义务；3) 附录II (技术和组织措施) 内容缺失, 导致SCC要求的具体安全保障措施无法核实；4) 附录I中存在数据类别描述不一致及参与方信息可能不完整的问题。这些缺陷共同构成了系统性合规风险, 数据传输的法律基础存在重大疑问。

(2) 模块选择是否正确

模块选择：正确

根据审查上下文, 申报的模块为模块二 (控制者向处理者传输), 与预期模块一致。模块选择正确。

(3) 标准条款是否被修改及其影响评估

存在修改：是

影响评估：高风险

审查发现第15(a)条被修改。该条款要求数据接收方在收到具有法律约束力的政府访问请求时, “立即 (promptly)” 通知数据输出方及数据主体 (如可能)。修改后的文本将通知义务弱化为“法律许可时”, 这赋予了数据接收方过大的自由裁量权, 可能导致通知不当延迟或完全规避, 从而损害数据主体权利及数据输出方采取应对措施的能力。此修改削弱了SCC作为传输工具的有效性, 违反了标准条款旨在确保透明度和及时响应的目的 [1]。

(4) 第三国传输风险和TIA完成情况

第三国传输目的地：印度

传输风险：高风险

印度未被欧盟委员会认定为提供充分数据保护水平的国家 (即不具备充分性决定)。因此, 本次传输属于向“第三国”的传输, 必须依赖GDPR第46条规定的适当保障措施 (此处为SCC), 并确保这些措施在实践中有效。

TIA完成情况：未提供

审查未发现已完成的传输影响评估 (TIA)。根据Schrems II案判决及EDPB指南, 在依赖SCC等工具向不具备充分性决定的第三国传输数据前, 数据输出方必须进行详细的TIA, 以评估当地法律 (特别是公共机构访问数据的可能性) 是否会影响SCC的遵守。未进行TIA构成重大程序性缺陷, 使得本次传输缺乏必要的法律前置评估 [3]。

(5) Schrems II补充措施是否到位

补充措施状态：未到位

审查未发现针对印度传输风险已实施任何经确认的技术、合同或组织性补充措施。根据EDPB Recommendations 01/2020，当TIA评估表明第三国法律可能妨碍SCC义务的履行时，必须采取补充措施以弥补差距，确保达到与欧盟实质等同的保护水平。当前状况下，技术、合同、组织三类补充措施均缺失，无法应对潜在的政府访问风险，导致SCC作为传输工具的有效性不足 [3]。

References: EDPB Recommendations 01/2020 Step 3; Commission Implementing Decision (EU) 2021/914 Recital (22) / Clause 15

条款级审查发现

第三章 条款级审查发现

1. 标准条款的修改与削弱

1.1 Clause 15(a) 通知义务的削弱

定位*: Clause 15(a)

原文引用*: 将“立即 (promptly)”通知修改为“法律许可时”通知。

问题类型*: 条款削弱

风险等级*: HIGH

风险分析*: 此修改将数据接收方 (data importer) 在收到具有法律约束力的数据披露请求时的通知义务，从一项及时、主动的义务转变为一项受制于第三国法律许可的、不确定的义务。这实质上削弱了SCCs为数据主体 (data subject) 和数据输出方 (data exporter) 提供的关键保障，使其无法及时知晓风险并采取应对措施，违反了SCCs确保有效保护的核心目的。

法规依据*: Commission Implementing Decision (EU) 2021/914 Recital

1 明确指出，数据接收方应尽可能 (where possible) 通知数据输出方和数据主体 [1]。将“promptly”替换为“法律许可时”与此精神相悖。

修改建议*: 必须将Clause 15(a)中的通知时限要求恢复为标准文本中的“立即 (promptly)”。

1.2 Clause 15 信息提供义务的语义削弱

定位*: Clause 15

原文引用*: 未提供具体修改文本，但审查指出“信息提供变为可自由裁量的 (made discretionary)”。

问题类型*: 条款削弱

风险等级*: HIGH

风险分析*: 若Clause 15中关于数据接收方向数据输出方提供其遵守义务所需信息的强制性要求被修改为可自由裁量，将严重破坏SCCs的问责制和透明度机制。数据输出方将无法有效监督传输后的处理活动，也无法履行其作为控制者或处理者应承担的责任。

法规依据*: 标准合同条款 (Clauses) 本身构成具有法律约束力的义务，任何使其核心监督与问责机制变为可自由裁量的修改，均会损害其作为GDPR第46条有效传输工具的效力。

修改建议*: 必须确保Clause 15中关于信息提供的义务是强制性的，并恢复为标准文本。

【待核验：缺少法规依据】

2. 附录 (Annex) 信息不完整与错误

2.1 Annex I.A 签约方信息不全

定位*: Annex I.A

原文引用*: 识别出的签约方少于2个。对接条款 (Docking Clause, Clause 7) 的签约方可能缺失。

问题类型*: Annex不完整

风险等级*: MEDIUM

风险分析*: Annex I.A 未完整、准确地列出所有受SCCs约束的签约方，导致合同主体不明，权利义务关系不清。这可能影响SCCs对相关方的法律约束力，并在发生争议时造成责任主体认定的困难。

法规依据*: EU 2021/914附件中的SCCs要求明确填写各方详细信息。

修改建议*: 必须根据实际数据传输关系，在Annex I.A中完整、准确地列明所有数据输出方和数据接收方。

【待核验：缺少法规依据】

2.2 Annex I.B 特殊类别数据误判

定位*: Annex I.B

原文引用*: 传输描述中包含健康/医疗数据相关术语，但未声明（NOT declared）为特殊类别数据。

问题类型*: 特殊类别误判

风险等级*: HIGH

风险分析*: 健康数据属于GDPR第

References: Commission Implementing Decision (EU) 2021/914 Recital (22) / Clause 15

法规依据与修改建议

第四章 法规依据与修改建议

4.1 本次审查引用的法规依据清单

本次合规审查严格依据以下欧盟数据保护法规、实施决定及监管指南进行：

- 1 《通用数据保护条例》（GDPR）第五章：特别是关于个人数据向第三国或国际组织传输的第44至49条，构成了跨境传输的法律基础。
- 2 欧盟委员会实施决定 (EU) 2021/914：即《标准合同条款》（SCC），特别是其序言（21）、（22）条及第14条、第15条的具体规定 [2][1]。
- 3 欧洲数据保护委员会（EDPB）《建议01/2020》：关于在 Schrems II 判决后为向第三国传输数据而采取的补充措施，特别是其“第三步”评估要求 [3]。
- 4 欧洲法院判决 Schrems II (C-311/18)：该判决确立了在依据GDPR第46条（如SCC）进行传输时，必须确保第三国法律不会损害SCC提供的保障，否则需采取补充措施或暂停传输。

4.2 按优先级排列的修改建议汇总

P0：必须在签署前修改

- 1 修正对标准条款的修改：必须将附录II（技术和组织措施）从空白状态修改为包含具体、有效的保护措施描述，以符合SCC的强制性要求及GDPR第28条和第32条的安全原则。
- 2 纠正特殊类别数据处理声明：必须在附录I.B中准确声明所传输的个人数据类型。鉴于传输描述中包含健康/医疗相关术语，必须根据GDPR第9条明确是否涉及特殊类别数据，并确保具备合法的处理依据（如明确同意），仅依赖SCC本身不足。
- 3 恢复强制性通知义务：必须将第15(a)条中数据进口方在收到具有法律约束力的披露请求时的通知义务，从“法律许可时”修改回SCC原文的“立即（promptly）”，不得削弱该核心保障 [1]。

P1：建议在首次传输前修改

- 1 完成并记录传输影响评估（TIA）：在向印度（非充分性决定国家）进行任何数据传输前，必须根据Schrems II判决和EDPB建议完成详细的TIA，并形成书面文件 [3]。该评估是证明SCC在目标国法律环境下有效的先决条件。

- 2 识别并实施补充措施：基于TIA结果，必须识别、实施并记录针对印度法律环境风险的有效补充措施（技术性、合同性、组织性），以确保传输达到欧盟“基本等同”的保护水平。
- 3 完善签约方信息：补充附录I.A中缺失的签约方信息，并确认是否适用对接条款（第7条）及其相关方。

P2：可持续改进项

- 1 建立TIA与补充措施的持续监控与更新机制：建立定期（例如每年）或在第三国法律发生重大变化时，重新评估TIA及补充措施有效性的流程。

4.3 建议的整改完成时限和复核要点

- P0项整改完成时限：签署SCC协议前。必须在合同生效前完成所有P0级别问题的修正。
- P1项整改完成时限：首次向印度传输个人数据前。所有P1级别的措施必须到位并完成文档化。

-

References: Commission Implementing Decision (EU) 2021/914 Recital (21) / Clause 14; Commission Implementing Decision (EU) 2021/914 Recital (22) / Clause 15; EDPB Recommendations 01/2020 Step 3